

3 Project 1: Secure Web-Based File Encryption and Management System

This chapter describes the first of the two project options. It presents the overview of the system to be built, its security requirements, the expected deliverables, and the deliverables of each of the three checkpoints.

3.1 Overview

This project builds on the Secure File Manager from the ICS0022 Secure Programming course. You will develop a web-based file encryption and management system that allows users to securely upload, encrypt and manage files. The focus is on server-side encryption, secure file handling, user authentication, and defending against common web vulnerabilities such as CSRF, XSS and file inclusion attacks.

You can get inspired by current open-source cloud hosting projects and how they handle encryption and security:

- NextCloud: <https://nextcloud.com/encryption/> and <https://nextcloud.com/secure/>
- OwnCloud:
https://doc.owncloud.com/webui/next/classic_ui/files/encrypting_files.html and
<https://owncloud.com/news/owncloud-data-security-measures/>

3.2 Requirements

The system must satisfy the following security requirements.

File encryption and decryption. Secure encryption for uploaded files. Users can upload, encrypt and download files securely, with data protected in transit using TLS. Ensure secure deletion of files from the server.

User authentication. A secure login system with password hashing. Sessions must be managed securely with protection against hijacking and fixation attacks.

CSRF and XSS defence. CSRF protection on all forms, particularly file upload and login. Content Security Policy and strict input validation to protect against XSS.

Input validation and secure file handling. Validate all user inputs, especially file uploads. Prevent SQL injection. Restrict file types and sanitize input to prevent file inclusion attacks.

Access control. Enforce per-user ownership on every file and record operation.

Error handling and logging. Generic user-facing errors that leak no stack traces or internals. Structured logging that records the event, the user or session identifier, the timestamp, the source address and the outcome. Never log secrets, tokens or passwords.

Secrets management. All secrets, such as database credentials, cryptographic keys, JWT secrets and SMTP credentials, are stored securely and never committed to the repository.

3.3 Deliverables

The following deliverables are submitted at the end of the project.

- A working web-based file encryption and management system.
- Documentation on how to set up and use the application.
- A project report detailing the encryption methods and security features, the input validation and web security measures, and the tests conducted including sample attack vectors and their mitigation.
- Test cases and results demonstrating the application's security and functionality.

3.4 Checkpoint deliverables

The three checkpoints of this project are described below. Each checkpoint is worth 5% of the course result and is verified in the lab session of the week indicated.

3.4.1 Checkpoint 1, threat model and architecture (Week 4)

Deliverables. A short design document plus an initialised repository.

- System architecture diagram showing the browser, the web application, the storage and the database, indicating where encryption happens and where the trust boundaries are.
- Threat model of the application mapped to the OWASP Top 10 and to the attack classes covered in Weeks 1–4, such as HTML and JavaScript injection, input tampering and client-side control bypass. Each threat listed with its intended mitigation.
- Technology stack chosen, covering the framework, the database and the cryptographic library, with a short justification, and the plan for serving the application over TLS.
- Planned authentication and session model, including cookie flags, session lifetime and how fixation is prevented.
- Repository initialised with a README stating the scope, the planned routes and features, and how to run it locally.

3.4.2 Checkpoint 2, core requirements implemented (Week 9)

Deliverables. A running web application in the repository, plus a short progress note.

- Basic working web interface with the core flows.
- Basic server-side file encryption and decryption.
- Basic secure authentication implemented with password hashing, and secure session management.
- Application served over TLS in the development setup.
- Run instructions that work on a clean machine, and a commit history showing incremental progress.

3.4.3 Checkpoint 3, near-final state (Week 12)

Deliverables. Feature-complete application, security test evidence, and a draft of the report.

- CSRF protection implemented on all state-changing forms, and verified with a demonstration attempt.
- XSS defences in place.
- Input validation and secure file handling completed.
- SQL injection prevented via prepared and parameterized statements throughout.
- Per-user access control enforced on every file operation, verified by attempting to access another user's file.
- Secure error handling and structured logging.
- Security test cases with results, including the sample attack vectors attempted and how each was mitigated.
- Draft report covering the Introduction, Implementation, Security Analysis and Conclusion, as described in Section 1.3.